

Индивидуальный проект

2 Этап

Панина Жанна Валерьевна

2026-03-21

Содержание I

- 1 Информация
- 2 Вводная часть
- 3 Цель работы
- 4 Задание
- 5 Теоретическое введение
- 6 Выполнение лабораторной работы
- 7 Результаты

Раздел 1

Информация

Панина Жанна Валерьевна студентка НКАбд-02-24 Российский
университет дружбы народов им. П. Лумумбы
1132246710@rudn.ru
https://github.com/zvpanina/study_2025-2026_infosec-intro

Раздел 2

Вводная часть

Раздел 3

Цель работы

Цель работы

Приобретение практических навыков по установке DVWA

Раздел 4

Задание

Установить дистрибутив DVWA в Kali Linux

Раздел 5

Теоретическое введение

DVWA - это уязвимое веб-приложение, разработанное на PHP и MySQL.

Некоторые из уязвимостей веб приложений, который содержит DVWA: - Брутфорс:

Брутфорс HTTP формы страницы входа - используется для тестирования инструментов по атаке на пароль методом грубой силы и показывает небезопасность слабых паролей. -

Исполнение (внедрение) команд: Выполнение команд уровня операционной системы. -

Межсайтовая подделка запроса (CSRF): Позволяет «атакующему» изменить пароль

администратора приложений. - Внедрение (инклюд) файлов: Позволяет «атакующему»

присоединить удалённые/локальные файлы в веб приложение. - SQL внедрение: Позволяет

«атакующему» внедрить SQL выражения в HTTP из поля ввода, DVWA включает слепое и

основанное на ошибке SQL внедрение. - Небезопасная выгрузка файлов: Позволяет

«атакующему» выгрузить вредоносные файлы на веб сервер. - Межсайтовый скриптинг

(XSS): «Атакующий» может внедрить свои скрипты в веб приложение/базу данных. DVWA

включает отражённую и хранимую XSS. - Пасхальные яйца: раскрытие полных путей, обход

аутентификации и некоторые другие.

DVWA имеет четыре уровня безопасности, они меняют уровень безопасности каждого веб приложения в DVWA: - Невозможный — этот уровень должен быть безопасным от всех уязвимостей. Он используется для сравнения уязвимого исходного кода с безопасным исходным кодом. - Высокий — это расширение среднего уровня сложности, со смесью более сложных или альтернативных плохих практик в попытке обезопасить код. Уязвимости не позволяют такой простор эксплуатации как на других уровнях. - Средний — этот уровень безопасности предназначен главным образом для того, чтобы дать пользователю пример плохих практик безопасности, где разработчик попытался сделать приложение безопасным, но потерпел неудачу. - Низкий — этот уровень безопасности совершенно уязвим и совсем не имеет защиты. Его предназначение быть примером среди уязвимых веб приложений, примером плохих практик программирования и служить платформой обучения базовым техникам эксплуатации. [@guide, @parasram]

Раздел 6

Выполнение лабораторной работы

Выполнение лабораторной работы

Перехожу в директорию `/var/www/html`. Затем клонирую нужный репозиторий GitHub (?@fig-001).

```
(zvpanina@kali)-[~]
$ cd /var/www/html/

(zvpanina@kali)-[/var/www/html]
$ git clone https://github.com/digininja/DVWA.git
fatal: could not create work tree dir 'DVWA': Permission denied

(zvpanina@kali)-[/var/www/html]
$ sudo git clone https://github.com/digininja/DVWA.git
[sudo] password for zvpanina:
Cloning into 'DVWA' ...
remote: Enumerating objects: 5676, done.
remote: Counting objects: 100% (25/25), done.
remote: Compressing objects: 100% (13/13), done.
remote: Total 5676 (delta 19), reused 12 (delta 12), pack-reused 5651 (from 2)
Receiving objects: 100% (5676/5676), 2.71 MiB | 5.34 MiB/s, done.
Resolving deltas: 100% (2834/2834), done.
```

Рисунок 1: Клонирование репозитория

Чтобы настроить DVWA, нужно перейти в каталог `/dvwa/config`, затем проверяю содержимое каталога (**?@fig-002**).

```
(zvipanina@kali)-[/var/www/html]
$ cd DVWA/

(zvipanina@kali)-[/var/www/html/DVWA]
$ ls
about.php      Dockerfile     index.php      README.ar.md   README.ko.md   README.uk.md   security.txt
CHANGELOG.md   docs          instructions.php README.es.md    README.md      README.vi.md   setup.php
compose.yml    dvwa         login.php      README.fa.md   README.pl.md   README.zh.md   tests
config        external     logout.php     README.fr.md   README.pt.md   robots.txt    vulnerabilities
COPYING.txt   favicon.ico   phpinfo.php    README.id.md   README.ru.md   SECURITY.md     security.php
database      hackable     php.ini        README.it.md   README.tr.md

(zvipanina@kali)-[/var/www/html/DVWA]
$ cd config/

(zvipanina@kali)-[/var/www/html/DVWA/config]
$ ls
config.inc.php.dist

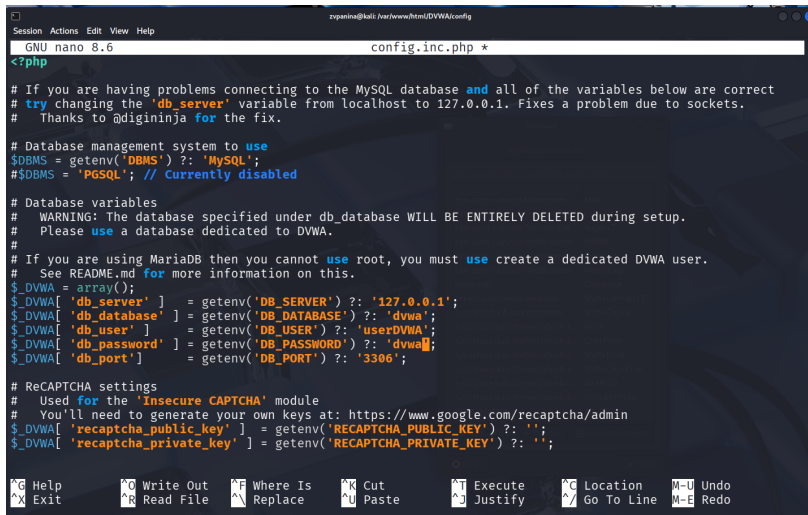
(zvipanina@kali)-[/var/www/html/DVWA/config]
$ sudo mv config.inc.php.dist config.inc.php

(zvipanina@kali)-[/var/www/html/DVWA/config]
$ ls
config.inc.php
```

Рисунок 2: Перемещение по директориям

Изменяю файл, используемый для настройки DVWA `config.inc.php.dist` на `config.inc.php`.

Далее открываю файл в текстовом редакторе nano (?@fig-003). Изменяю данные об имени пользователя и пароле.



```
GNU nano 8.6 config.inc.php *
<?php

# If you are having problems connecting to the MySQL database and all of the variables below are correct
# try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes a problem due to sockets.
# Thanks to @diginiinja for the fix.

# Database management system to use
$DBMS = getenv('DBMS') ?: 'MySQL';
$DBMS = 'PGSQL'; // Currently disabled

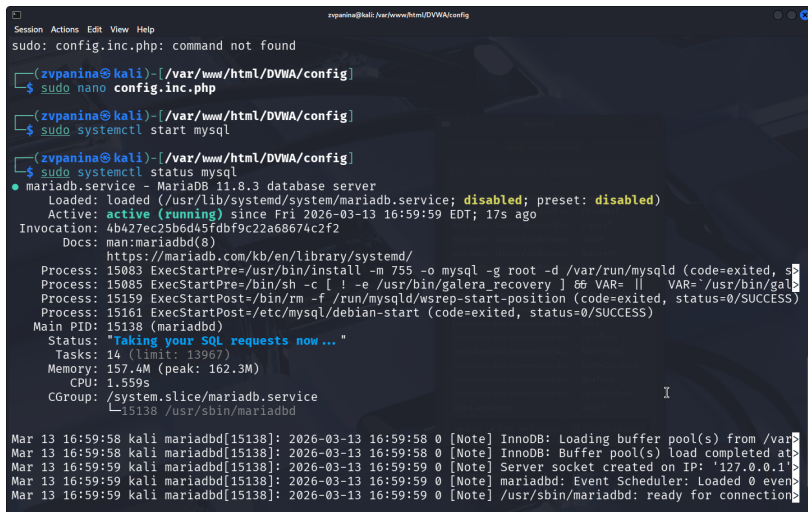
# Database variables
# WARNING: The database specified under db_database WILL BE ENTIRELY DELETED during setup.
# Please use a database dedicated to DVWA.
#
# If you are using MariaDB then you cannot use root, you must use create a dedicated DVWA user.
# See README.md for more information on this.
$_DVWA = array();
$_DVWA['db_server'] = getenv('DB_SERVER') ?: '127.0.0.1';
$_DVWA['db_database'] = getenv('DB_DATABASE') ?: 'dvwa';
$_DVWA['db_user'] = getenv('DB_USER') ?: 'userDVWA';
$_DVWA['db_password'] = getenv('DB_PASSWORD') ?: 'dvwa';
$_DVWA['db_port'] = getenv('DB_PORT') ?: '3306';

# ReCAPTCHA settings
# Used for the 'Insecure CAPTCHA' module
# You'll need to generate your own keys at: https://www.google.com/recaptcha/admin
$_DVWA['recaptcha_public_key'] = getenv('RECAPTCHA_PUBLIC_KEY') ?: '';
$_DVWA['recaptcha_private_key'] = getenv('RECAPTCHA_PRIVATE_KEY') ?: '';

^G Help      ^O Write Out  ^F Where Is   ^K Cut        ^T Execute    ^C Location   M-U Undo
^X Exit      ^R Read File  ^N Replace    ^U Paste      ^_ Justify    ^_/ Go To Line  M-E Redo
```

Рисунок 3: Редактирование файла в nano

По умолчанию в Kali Linux установлен mysql, поэтому можно его запустить без предварительного скачивания, далее выполняю проверку, запущен ли процесс (?@fig-004).



```
Session Actions Edit View Help
sudo: config.inc.php: command not found

(zvpanina@kali)-[/var/www/html/DVWA/config]
$ sudo nano config.inc.php

(zvpanina@kali)-[/var/www/html/DVWA/config]
$ sudo systemctl start mysql

(zvpanina@kali)-[/var/www/html/DVWA/config]
$ sudo systemctl status mysql
● mariadb.service - MariaDB 11.8.3 database server
   Loaded: loaded (/usr/lib/systemd/system/mariadb.service; disabled; preset: disabled)
   Active: active (running) since Fri 2026-03-13 16:59:59 EDT; 17s ago
     Invocation: 4b427ec25b6d45fdbf9c22a68674c2f2
       Docs: man:mariadb(8)
             https://mariadb.com/kb/en/library/systemd/
   Process: 15083 ExecStartPre=/usr/bin/install -m 755 -o mysql -g root -d /var/run/mysqld (code=exited, s>
   Process: 15085 ExecStartPre=/bin/sh -c [ ! -e /usr/bin/galera_recovery ] && VAR= || VAR=/usr/bin/gal>
   Process: 15159 ExecStartPost=/bin/rm -f /run/mysqld/wsrep-start-position (code=exited, status=0/SUCCESS)
   Process: 15161 ExecStartPost=/etc/mysql/debian-start (code=exited, status=0/SUCCESS)
   Main PID: 15138 (mariabdd)
    Status: "Taking your SQL requests now ..."
      Tasks: 14 (limit: 13967)
     Memory: 157.4M (peak: 162.3M)
        CPU: 1.559s
    CGroup: /system.slice/mariadb.service
            └─15138 /usr/sbin/mariabdd

Mar 13 16:59:58 kali mariabdd[15138]: 2026-03-13 16:59:58 0 [Note] InnoDB: Loading buffer pool(s) from /var>
Mar 13 16:59:58 kali mariabdd[15138]: 2026-03-13 16:59:58 0 [Note] InnoDB: Buffer pool(s) load completed at>
Mar 13 16:59:59 kali mariabdd[15138]: 2026-03-13 16:59:59 0 [Note] Server socket created on IP: '127.0.0.1'>
Mar 13 16:59:59 kali mariabdd[15138]: 2026-03-13 16:59:59 0 [Note] mariabdd: Event Scheduler: Loaded 0 even>
Mar 13 16:59:59 kali mariabdd[15138]: 2026-03-13 16:59:59 0 [Note] /usr/sbin/mariabdd: ready for connection>
```

Рисунок 4: Запуск mysql

Авторизируюсь в базе данных от имени пользователя root (?@fig-005). Появляется командная строка с приглашением «MariaDB». Далее создаем в ней нового пользователя, используя учетные данные из файла config.inc.php. Теперь нужно пользователю предоставить привилегии для работы с этой базой данных.

```
(zvpanina@kali)-[~]
$ cd /etc/php

(zvpanina@kali)-[/etc/php]
$ cd 8.4

(zvpanina@kali)-[/etc/php/8.4]
$ cd apache2

(zvpanina@kali)-[/etc/php/8.4/apache2]
$ ls
conf.d  php.ini

(zvpanina@kali)-[/etc/php/8.4/apache2]
$ sudo nano php.ini
[sudo] password for zvpanina: █
```

Рисунок 5: Авторизация в базе данных и предоставление привилегий

Необходимо настроить сервер apache2, перехожу в соответствующую директорию (?@fig-006). В файле `php.ini` нужно будет изменить один параметр, поэтому открываю файл в текстовом редакторе.

```
(zvpanina@kali)-[~]
$ cd /etc/php

(zvpanina@kali)-[/etc/php]
$ cd 8.4

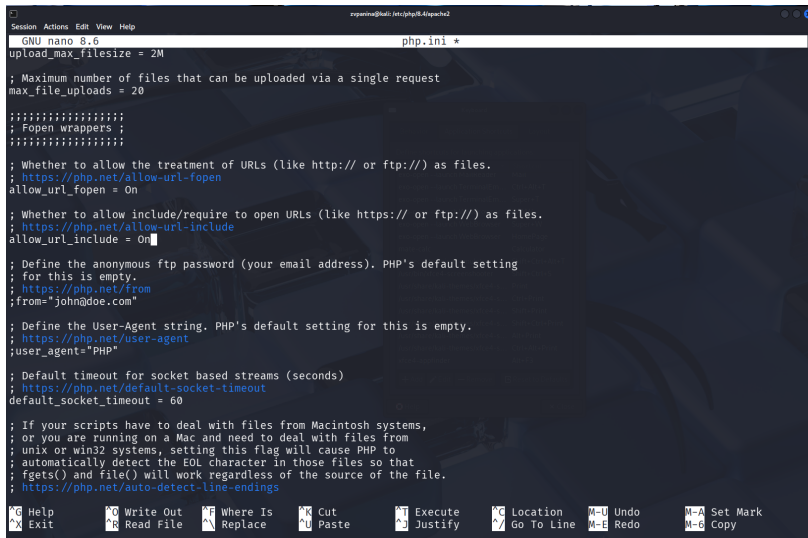
(zvpanina@kali)-[/etc/php/8.4]
$ cd apache2

(zvpanina@kali)-[/etc/php/8.4/apache2]
$ ls
conf.d  php.ini

(zvpanina@kali)-[/etc/php/8.4/apache2]
$ sudo nano php.ini
[sudo] password for zvpanina: █
```

Рисунок 6: Перемещение между директориями

В файле параметры `allow_url_fopen` и `allow_url_include` должны быть поставлены как `On` (?@fig-007).



```
GNU nano 8.6 php.ini *
upload_max_filesize = 2M

; Maximum number of files that can be uploaded via a single request
max_file_uploads = 20

;;;;;;;;;;;;;;;;;;;;;;;;;
; Fopen wrappers ;
;;;;;;;;;;;;;;;;;;;;;;;;;

; Whether to allow the treatment of URLs (like http:// or ftp://) as files.
; https://php.net/allow-url-fopen
allow_url_fopen = On

; Whether to allow include/require to open URLs (like https:// or ftp://) as files.
; https://php.net/allow-url-include
allow_url_include = On

; Define the anonymous ftp password (your email address). PHP's default setting
; for this is empty.
; https://php.net/from
;from="john@doe.com"

; Define the User-Agent string. PHP's default setting for this is empty.
; https://php.net/user-agent
user_agent="PHP"

; Default timeout for socket based streams (seconds)
; https://php.net/default-socket-timeout
default_socket_timeout = 60

; If your scripts have to deal with files from Macintosh systems,
; or you are running on a Mac and need to deal with files from
; unix or win32 systems, setting this flag will cause PHP to
; automatically detect the EOL character in those files so that
; fgets() and file() will work regardless of the source of the file.
; https://php.net/auto-detect-line-endings
```

Help Write Out Where Is Cut Execute Location M-U Undo M-A Set Mark
Exit Read File Replace Paste Justify Go To Line M-E Redo M-E Copy

Запускаем службу веб-сервера apache и проверяем, запущена ли служба (?@fig-008).

```
(zvpanina@kali)-[/etc/php/8.4/apache2]
$ sudo systemctl start apache2

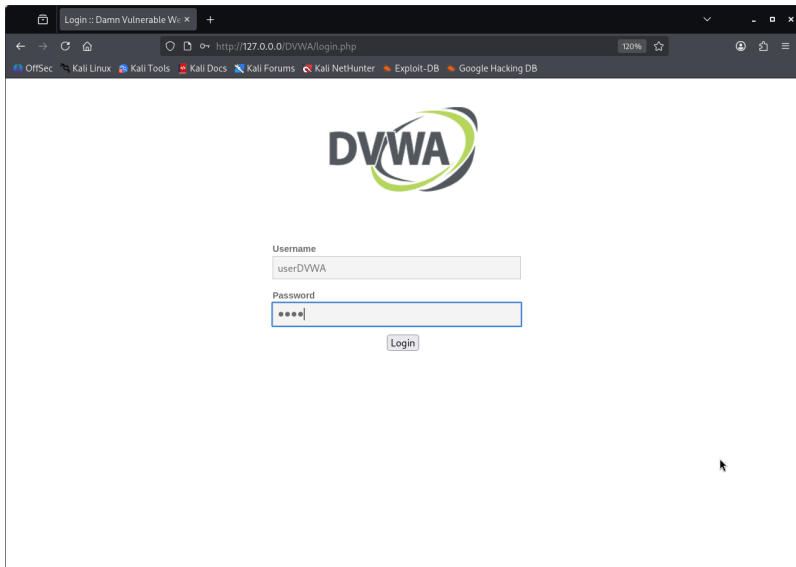
(zvpanina@kali)-[/etc/php/8.4/apache2]
$ status apache2
Command 'status' not found, did you mean:
  command 'statfs' from deb gocryptfs
  command 'states' from deb encrypt
Try: sudo apt install <deb name>

(zvpanina@kali)-[/etc/php/8.4/apache2]
$ systemctl status apache2
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; disabled; preset: disabled)
   Active: active (running) since Fri 2026-03-13 17:26:12 EDT; 33s ago
     Invocation: 47b78e32b5f647a7be12477f73ce030c
       Docs: https://httpd.apache.org/docs/2.4/
    Process: 28087 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUCCESS)
   Main PID: 28103 (apache2)
      Tasks: 6 (limit: 2116)
     Memory: 20.4M (peak: 20.7M)
        CPU: 63ms
    CGroup: /system.slice/apache2.service
            └─28103 /usr/sbin/apache2 -k start
              └─28106 /usr/sbin/apache2 -k start
                └─28107 /usr/sbin/apache2 -k start
                  └─28108 /usr/sbin/apache2 -k start
                    └─28109 /usr/sbin/apache2 -k start
                      └─28110 /usr/sbin/apache2 -k start

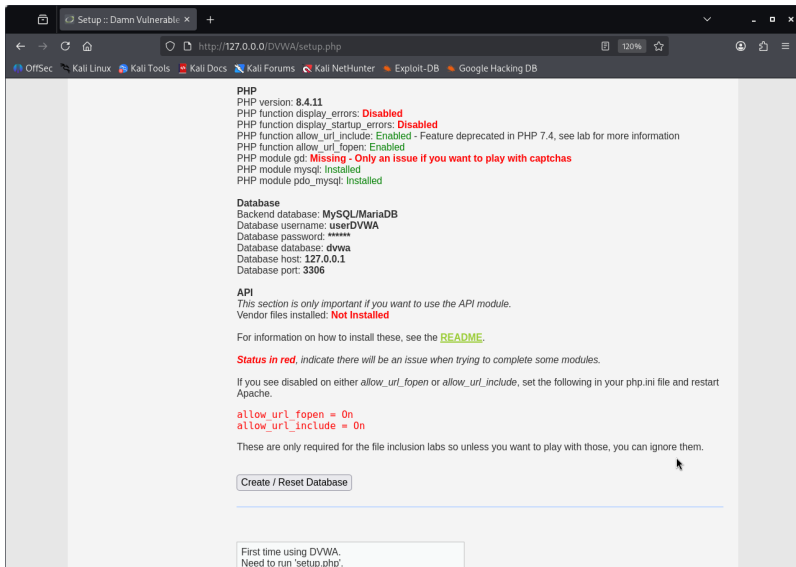
Mar 13 17:26:12 kali systemd[1]: Starting apache2.service - The Apache HTTP Server...
Mar 13 17:26:12 kali apachectl[28102]: AH00558: apache2: Could not reliably determine the server's fully qualified domain name
Mar 13 17:26:12 kali systemd[1]: Started apache2.service - The Apache HTTP Server.
lines 1-21/21 (END)
```

Рисунок 8: Запуск службы

Мы настроили DVWA, Apache и базу данных, поэтому открываем браузер и запускаем веб-приложение, введя 127.0.0/DVWA (?@fig-009).



Прокручиваем страницу вниз и нажимаем на кнопку create\reset database (?@fig-010).



Авторизуюсь с помощью предложенных по умолчанию данных (?@fig-011).

Username

admin

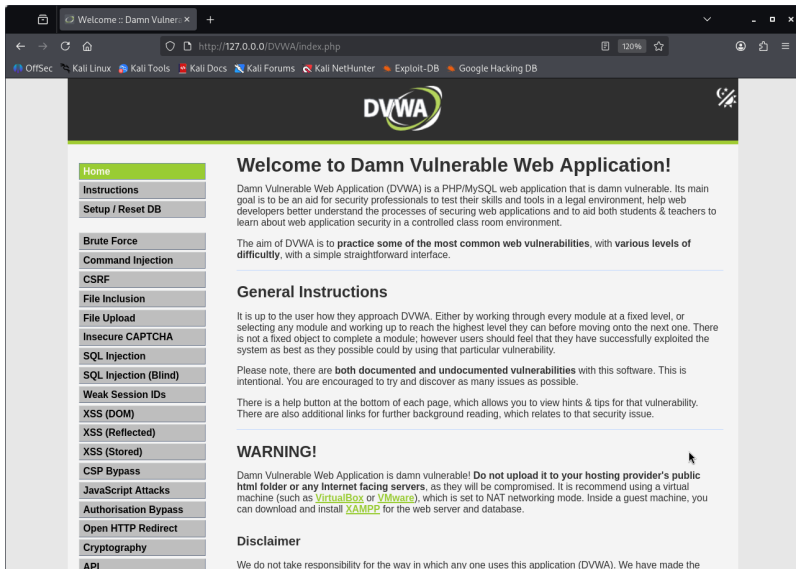
Password

.....

Login

Login failed

Оказываюсь на домашней странице веб-приложения, на этом установка окончена (?@fig-012).



Раздел 7

Результаты

В ходе работы я приобрела практические навыки по установке уязвимого веб-приложения DVWA.

...